SOINT
Soluciones Integrales & Tecnológicas

Reporte Ejecutivo: Riesgos GRC y SoD

www.soint.co | nbernal@soint.co

Generado por SOINT AI Assessment Platform

🚨 Diagnóstico Crítico de Vulnerabilidades

1. Tablero Cuantitativo de Vulnerabilidades Detectadas

Vector de Riesgo GRC	N° de Fallos / Casos Detectados	Tablas Involucradas	Nivel de Severidad
1. Síndrome de Dios / Superusuarios	5	UST04, AGR_1251, AGR_USERS	Crítico
2. Bypass de Auditoría en Tablas	4	AGR_1251, AGR_USERS, AGR_AGRS	Crítico
3. Conflictos SoD Financiero/Compras y Niveles Org	5	AGR_USERS, AGR_AGRS, AGR_1252, AGR_TCODES	Alto
4. Puertas Traseras de Desarrollo en Prod	2	AGR_1251, AGR_TCODES, AGR_USERS, AGR_DEFINE	Crítico
5. Usuarios Fantasma / Cuentas Expiradas Activas	4	USR02, AGR_USERS, UST04	Alto
TOTAL DE VULNERABILIDADES A CORREGIR	**20**	**8 tablas SAP auditadas**	**Riesgo Global Crítico**

2. Detalle Ejecutivo de Hallazgos Críticos

Vector 1: Síndrome de Dios / Superusuarios

- **Evidencia Cuantificada:** 4 cuentas con perfiles irrestrictos (`SAP_ALL`, `SAP_NEW`, `Z_PRF_ALL`) y 1 rol activo con autorización comodín `S_TCODE = *`.
- **Impacto de Negocio:** Control absoluto no monitoreado, evasión total de controles internos y ejecución de cualquier transacción del ERP.
- **Elementos Afectados (Censurados):** `[USUARIO_EXTERNO_01]`, `[USUARIO_TI_02]`, `[USUARIO_SISTEMA_03]`, `[CUENTA_FIREFIGTHER_04]`, `[ROL_SOPORTE_AMPLIO]`.

Vector 2: Bypass de Auditoría en Tablas

- **Evidencia Cuantificada:** 2 roles permiten modificación directa (`ACTVT 02`) en `S_TABU_DIS` (*) y `S_TABU_NAM` (tabla `BSEG`), impactando a 4 cuentas.
- **Impacto de Negocio:** Manipulación manual y directa de registros contables y asientos financieros sin dejar traza transaccional ni documento contable.
- **Elementos Afectados (Censurados):** `[ROL_TABLAS_01]`, `[ROL_SOPORTE_02]`, asignados a `[USUARIO_FINANZAS_01]` y 3 cuentas más.

Vector 3: Conflictos SoD Financiero/Compras y Niveles Org

- **Evidencia Cuantificada:** 2 usuarios combinan el ciclo completo de compras y pagos (`ME21N`/`MK01` + `F110`/`FK01`), con 3 valores organizacionales abiertos (`$BUKRS=*`, `$EKORG=*`, `$KOSTL=*`).
- **Impacto de Negocio:** Riesgo inminente de fraude por creación de proveedores ficticios y emisión autónoma de pagos entre todas las sociedades del grupo.
- **Elementos Afectados (Censurados):** `[USUARIO_OPERATIVO_01]`, `[USUARIO_DIRECTIVO_02]`, `[ROL_COMPUESTO_GERENCIAL]`.

Vector 4: Puertas Traseras de Desarrollo en Prod

- **Evidencia Cuantificada:** 1 rol creado indebidamente por `SAP*` otorga `SE38`, `SE80` y `S_DEVELOP` (`01`, `02`) asignado a 2 cuentas operativas.
- **Impacto de Negocio:** Modificación directa de código fuente en productivo, fuga deliberada de información y vulneración del ciclo de transporte de cambios.
- **Elementos Afectados (Censurados):** `[ROL_DEV_PROD]`, asignado a `[DEV_EXTERNO_01]` y `[USUARIO_DEV_02]`.

Vector 5: Usuarios Fantasma / Cuentas Expiradas Activas

- **Evidencia Cuantificada:** 1 cuenta con vigencia vencida en 2023 aún activa con `SAP_ALL`, 2 asignaciones huérfanas en roles críticos sin maestro en `USR02`, y 1 bombero inconsistente.
- **Impacto de Negocio:** Accesos no atribuibles ni rastreables ante auditorías externas, facilitando suplantaciones de identidad con privilegios administrativos (`SU01`/`PFCG`).
- **Elementos Afectados (Censurados):** `[USUARIO_EXPIRADO_EXTERNO]`, `[USUARIO_HUERFANO_SEGURIDAD]`, `[USUARIO_HUERFANO_ABAP]`.

3. Dictamen y Plan de Remediación Inmediata

El entorno SAP auditado se encuentra en **Riesgo Crítico Inmediato** por concentración severa de privilegios, segregación de funciones rota y bypass de pistas de auditoría. Para desanonimizar la matriz de hallazgos con los nombres reales de usuarios, roles y el plan de remediación técnica inmediata, agende una sesión de trabajo con el equipo de **SOINT**: **www.soint.co** | **nbernal@soint.co**.